Write-up: Oopsie

Plataforma: HackTheBox

Dificuldade: Muito fácil

Data de Resolução: 14/04/2026

Sumário

1 Visão Geral **2**

2 Reconhecimento **2**

3 Exploração **2**
3.1 Identificação da Vulnerabilidade 2
3.2 Execução do Exploit 3

4 Movimentação Lateral **3**

5 Escalada de Privilégios **3**

6 Conclusão **4**

7 Referências **4**

1 Visão Geral

Este desafio explora diversos conceitos fundamentais de segurança ofensiva, como a interceptação de requisições via proxy e a exploração de falhas comuns, incluindo IDOR (*Insecure Direct Object Reference*) e o upload irrestrito de arquivos. Por fim, demonstra-se como um binário configurado de forma insegura pode permitir a escalada de privilégios via ou execução indevida.

2 Reconhecimento

Inicialmente, realizei o escaneamento de portas com o `nmap`, obtendo os seguintes serviços ativos:

```
┌──(kali㉿kali)-[~/Desktop/ofsec]
└─$ nmap 10.129.113.169 -sV
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-24 13:20 EDT
Nmap scan report for 10.129.113.169
Host is up (0.54s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
80/tcp open  http    Apache httpd 2.4.29
Service Info: Host: 127.0.1.1; OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Figura 1: resultado do nmap

Ao acessar o endereço IP da máquina no navegador, foi visualizada uma página institucional. Após uma análise superficial, não foram encontrados pontos de entrada evidentes. Seguindo as orientações do HackTheBox, utilizei o Burp Suite para interceptar o tráfego. Através da análise das requisições e respostas, identifiquei o endpoint oculto `/cdn-cgi/login`.

1	http://10.129.113.209	GET	/	200	11162	HTML		Welcome
7	http://10.129.113.209	GET	/cdn-cgi/scripts/5c5dd728/cloudfla...	404	493	HTML	js	404 Not Found
8	http://10.129.113.209	GET	/cdn-cgi/login/script.js	200	293	script	js	
9	http://10.129.113.209	GET	/js/min.js	200	4197	script	js	
10	http://10.129.113.209	GET	/js/index.js	200	293	script	js	
13	http://10.129.113.209	GET	/fonts/fontawesome-webfont.woff2... ✓	404	492	HTML	woff2	404 Not Found
14	http://10.129.113.209	GET	/fonts/fontawesome-webfont.woff?... ✓	404	492	HTML	woff	404 Not Found
15	https://fonts.gstatic.com	GET	/s/nunitosans/v5/pe03MImSLYBIv1...	200	38527		ttf	
16	https://fonts.gstatic.com	GET	/s/nunitosans/v5/pe03MImSLYBIv1...	200	39043		ttf	
17	https://fonts.gstatic.com	GET	/s/nunitosans/v5/pe0qMImSLYBIv1...	200	39475		ttf	
19	http://10.129.113.209	GET	/favicon.ico	404	492	HTML	ico	404 Not Found

Figura 2: Tela do proxy onde foi encontrado a página de login

Acessando esta página, é possível realizar o login como visitante (*Guest*), o que libera acesso a novas áreas do sistema para exploração.

Resultados Relevantes:

- **Porta 80/tcp:** Servidor Apache (identificado endpoint `/cdn-cgi/login`).
- **Porta 22/tcp:** OpenSSH 8.2p1.

3 Exploração

3.1 Identificação da Vulnerabilidade

Navegando pelas páginas autenticadas, identifiquei uma funcionalidade de upload de arquivos. Sabe-se que esse recurso pode ser explorado para obter uma *reverse shell*, contudo, a página exige privilégios de administrador.

Ao analisar a página de gerenciamento de contas, observei que a URL continha um parâmetro de ID (`?id=X`), sugerindo uma vulnerabilidade de IDOR.

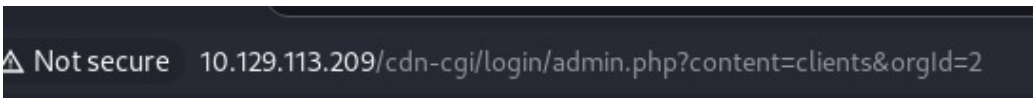

Figura 3: ULR com possível IDOR

3.2 Execução do Exploit

A vulnerabilidade de IDOR foi confirmada ao alterar o valor do parâmetro, o que permitiu visualizar os dados do usuário administrador, incluindo seu *cookie* de sessão e ID.

Com as credenciais de administrador obtidas, utilizei a funcionalidade de upload para enviar um arquivo PHP malicioso (*reverse shell*). Com base na estrutura do site, identifiquei que os arquivos enviados são armazenados no diretório `/uploads`. Ao acessar o arquivo via navegador e manter um *listener* ativo, consegui acesso inicial ao sistema como o usuário `www-data`.

4 Movimentação Lateral

Após obter acesso inicial, busquei por credenciais no sistema de arquivos. Utilizei o comando `grep` para procurar referências ao usuário "robert".

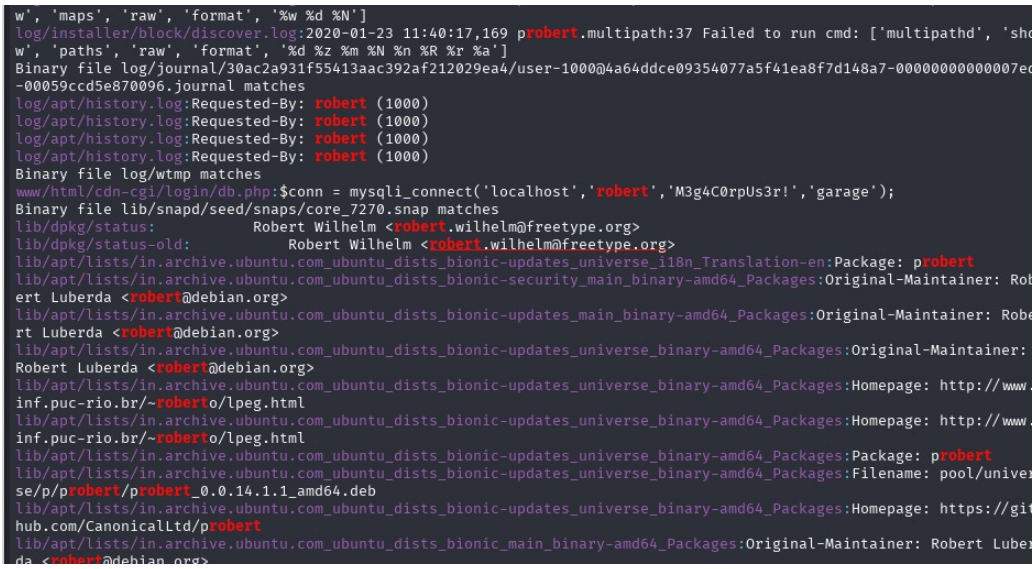

Figura 4: resultado do grep onde encontramos o usuário e senha

Embora o comando tenha apresentado lentidão em alguns diretórios, a busca manual em arquivos de configuração e *logs* permitiu encontrar uma senha em texto claro. Utilizando essas credenciais via SSH, realizei o login como o usuário `robert`, onde localizei a primeira *flag* (`user.txt`).

5 Escalada de Privilégios

Para a escalada de privilégios, utilizei o comando `find` para localizar binários com o bit SUID definido. Identifiquei o executável `bugtracker`.

Ao analisar o comportamento do binário, notei que ele executa o comando `cat` de forma relativa (sem o caminho absoluto). Isso permite realizar um ataque de *Path Hijacking*, criando um script falso chamado `cat` que executa uma shell (`/bin/sh`) e adicionando o diretório atual ao início da variável de ambiente `$PATH`.

Alternativamente, foi possível explorar a execução para invocar o editor `vim` com privilégios elevados, permitindo a abertura de uma shell de *root*. Com o acesso total, a *flag* final foi recuperada em `/root/root.txt`.

Figura 5: Mostrando a escalação de privilégio

6 Conclusão

A exploração da máquina **Oopsie** demonstrou uma cadeia típica de vulnerabilidades web e de sistema. O ataque iniciou-se com a descoberta de um endpoint oculto e uma falha de **IDOR**, que permitiu a escalada de privilégios horizontal para administrador. A partir disso, o **upload irrestrito de arquivos** viabilizou a execução remota de código (RCE). Por fim, a **má configuração de permissões SUID** em um binário customizado permitiu o comprometimento total do sistema (root).

7 Referências

HackTheBox - Oopsie

`https://app.hackthebox.com/machines/Oopsie`

OWASP: Insecure Direct Object Reference (IDOR)

`https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/05-Authorization_Testing/04-Testing_for_Insecure_Direct_Object_References`

GTFOBins - Privilege Escalation via SUID/Sudo

`https://gtfobins.github.io/`

PayloadsAllTheThings - Reverse Shell Cheat Sheet

`https://github.com/swisskyrepo/PayloadsAllTheThings`